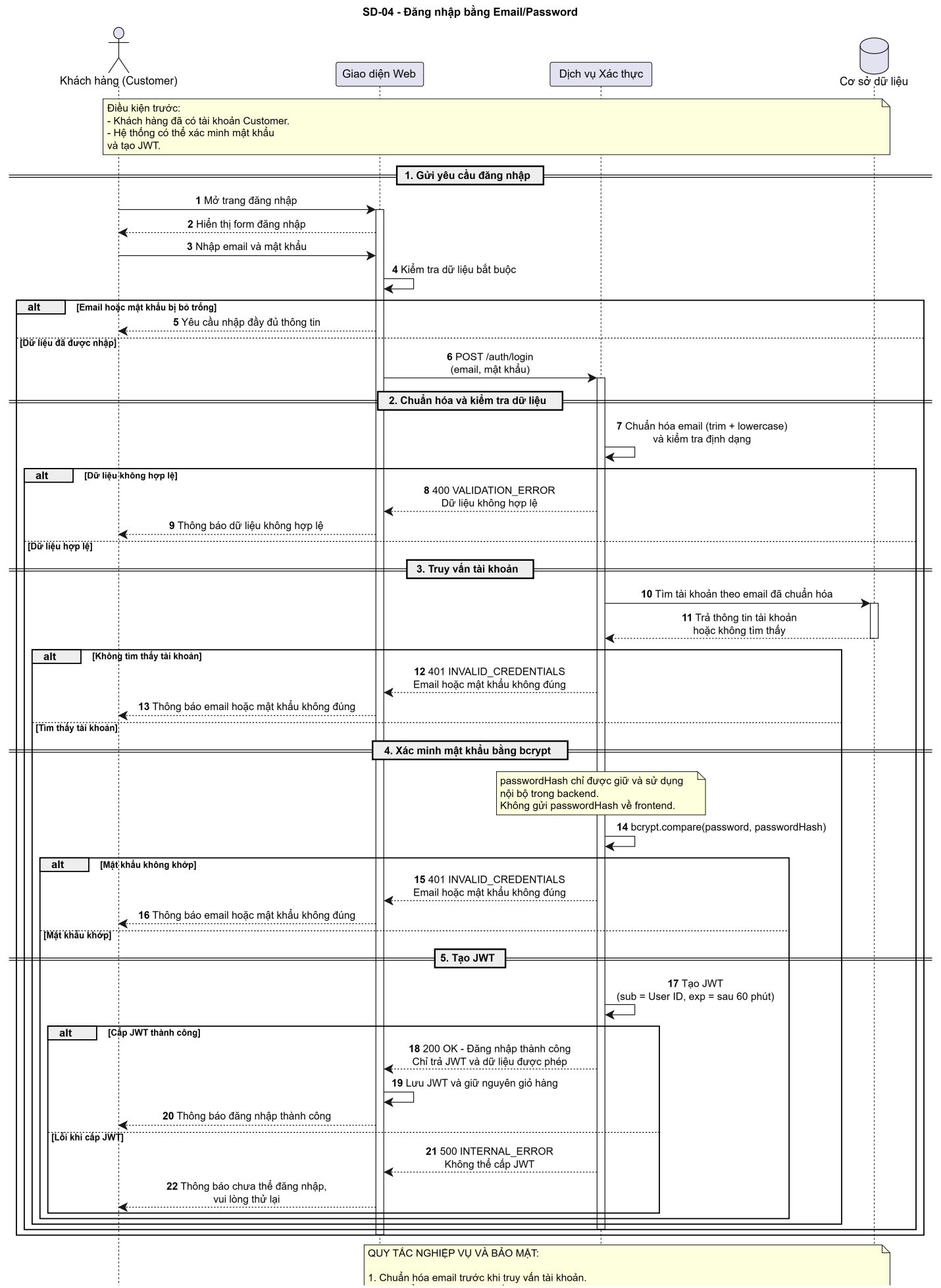
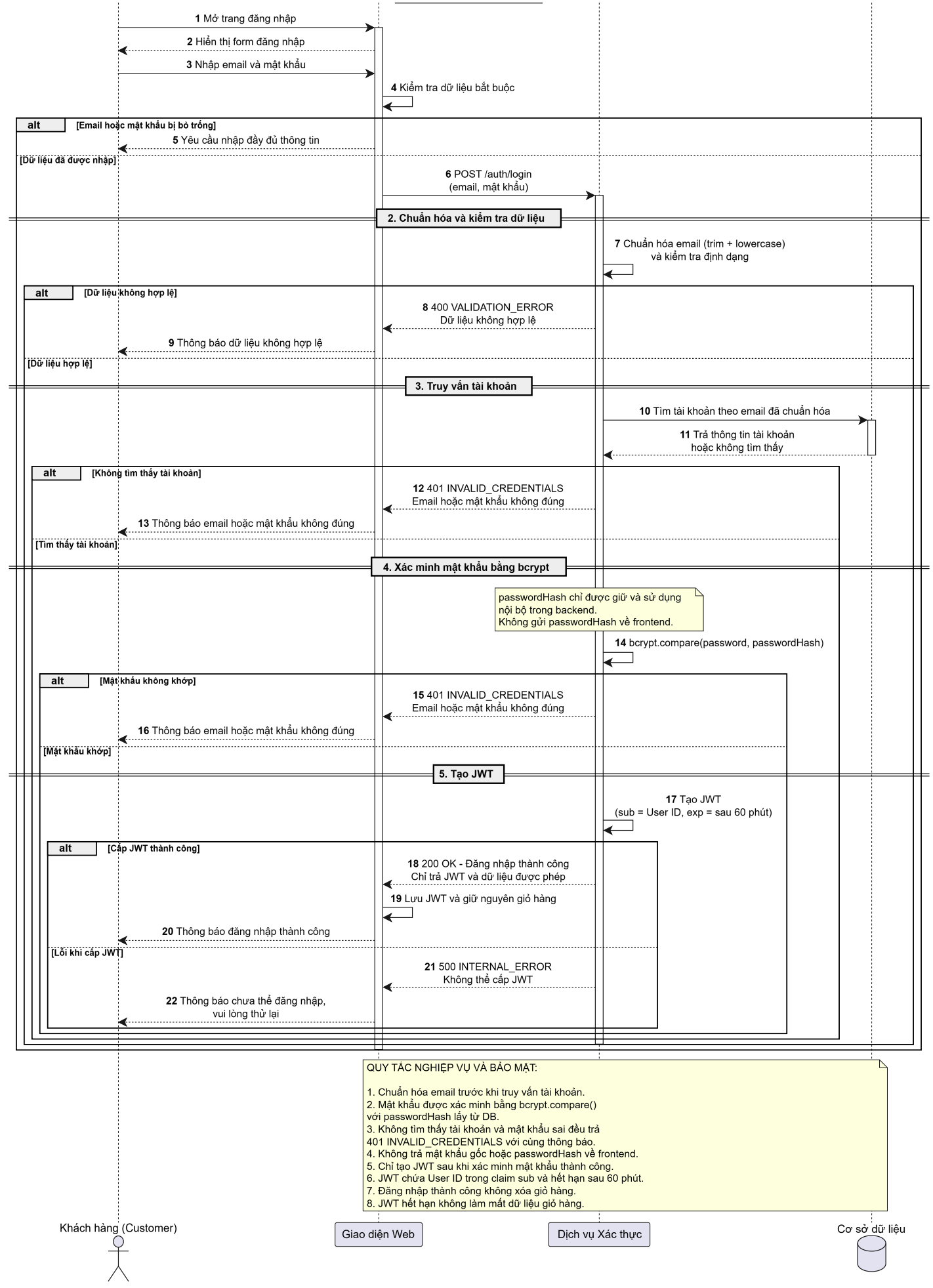

SD-04 - Đăng nhập bằng Email/Password
Khách hàng (Customer)
Giao diện Web
Dịch vụ Xác thực
Cơ sở dữ liệu
Điều kiện trước:
- Khách hàng đã có tài khoản Customer.
- Hệ thống có thể xác minh mật khẩu và tạo JWT.
1. Gửi yêu cầu đăng nhập
1 Mở trang đăng nhập
2 Hiển thị form đăng nhập
3 Nhập email và mật khẩu
4 Kiểm tra dữ liệu bắt buộc
alt [Email hoặc mật khẩu bị bỏ trống]
5 Yêu cầu nhập đầy đủ thông tin
[Dữ liệu đã được nhập]
6 POST /auth/login (email, mật khẩu)
2. Chuẩn hóa và kiểm tra dữ liệu
7 Chuẩn hóa email (trim + lowercase) và kiểm tra định dạng
alt [Dữ liệu không hợp lệ]
8 400 VALIDATION_ERROR Dữ liệu không hợp lệ
9 Thông báo dữ liệu không hợp lệ
[Dữ liệu hợp lệ]
3. Truy vấn tài khoản
10 Tìm tài khoản theo email đã chuẩn hóa
11 Trả thông tin tài khoản hoặc không tìm thấy
alt [Không tìm thấy tài khoản]
12 401 INVALID_CREDENTIALS Email hoặc mật khẩu không đúng
13 Thông báo email hoặc mật khẩu không đúng
[Tìm thấy tài khoản]
4. Xác minh mật khẩu bằng bcrypt
passwordHash chỉ được giữ và sử dụng nội bộ trong backend. Không gửi passwordHash về frontend.
14 bcrypt.compare(password, passwordHash)
alt [Mật khẩu không khớp]
15 401 INVALID_CREDENTIALS Email hoặc mật khẩu không đúng
16 Thông báo email hoặc mật khẩu không đúng
[Mật khẩu khớp]
5. Tạo JWT
17 Tạo JWT (sub = User ID, exp = sau 60 phút)
alt [Cấp JWT thành công]
18 200 OK - Đăng nhập thành công Chỉ trả JWT và dữ liệu được phép
19 Lưu JWT và giữ nguyên giỏ hàng
20 Thông báo đăng nhập thành công
[Lỗi khi cấp JWT]
21 500 INTERNAL_ERROR Không thể cấp JWT
22 Thông báo chưa thể đăng nhập, vui lòng thử lại
QUY TẮC NGHIỆP VỤ VÀ BẢO MẬT:
1. Chuẩn hóa email trước khi truy vấn tài khoản.


1 Mở trang đăng nhập
2 Hiển thị form đăng nhập
3 Nhập email và mật khẩu
4 Kiểm tra dữ liệu bắt buộc
alt [Email hoặc mật khẩu bị bỏ trống]
5 Yêu cầu nhập đầy đủ thông tin
[Dữ liệu đã được nhập]
6 POST /auth/login
(email, mật khẩu)
2. Chuẩn hóa và kiểm tra dữ liệu
7 Chuẩn hóa email (trim + lowercase)
và kiểm tra định dạng
alt [Dữ liệu không hợp lệ]
8 400 VALIDATION_ERROR
Dữ liệu không hợp lệ
9 Thông báo dữ liệu không hợp lệ
[Dữ liệu hợp lệ]
3. Truy vấn tài khoản
10 Tìm tài khoản theo email đã chuẩn hóa
11 Trả thông tin tài khoản
hoặc không tìm thấy
alt [Không tìm thấy tài khoản]
12 401 INVALID_CREDENTIALS
Email hoặc mật khẩu không đúng
13 Thông báo email hoặc mật khẩu không đúng
[Tìm thấy tài khoản]
4. Xác minh mật khẩu bằng bcrypt
passwordHash chỉ được giữ và sử dụng
nội bộ trong backend.
Không gửi passwordHash về frontend.
14 bcrypt.compare(password, passwordHash)
alt [Mật khẩu không khớp]
15 401 INVALID_CREDENTIALS
Email hoặc mật khẩu không đúng
16 Thông báo email hoặc mật khẩu không đúng
[Mật khẩu khớp]
5. Tạo JWT
17 Tạo JWT
(sub = User ID, exp = sau 60 phút)
alt [Cấp JWT thành công]
18 200 OK - Đăng nhập thành công
Chỉ trả JWT và dữ liệu được phép
19 Lưu JWT và giữ nguyên giỏ hàng
20 Thông báo đăng nhập thành công
[Lỗi khi cấp JWT]
21 500 INTERNAL_ERROR
Không thể cấp JWT
22 Thông báo chưa thể đăng nhập,
vui lòng thử lại
QUY TẮC NGHIỆP VỤ VÀ BẢO MẬT:
1. Chuẩn hóa email trước khi truy vấn tài khoản.
2. Mật khẩu được xác minh bằng bcrypt.compare()
với passwordHash lấy từ DB.
3. Không tìm thấy tài khoản và mật khẩu sai đều trả
401 INVALID_CREDENTIALS với cùng thông báo.
4. Không trả mật khẩu gốc hoặc passwordHash về frontend.
5. Chỉ tạo JWT sau khi xác minh mật khẩu thành công.
6. JWT chứa User ID trong claim sub và hết hạn sau 60 phút.
7. Đăng nhập thành công không xóa giỏ hàng.
8. JWT hết hạn không làm mất dữ liệu giỏ hàng.
Khách hàng (Customer)
Giao diện Web
Dịch vụ Xác thực
Cơ sở dữ liệu